# TOURSHIELD

## API de Turismo e Reservas

## Fraude de benefícios e geolocalização

### Projeto de Bloco | Trabalho Prático 1

**Helena Gomes**
25 de outubro de 2026

Competência integradora: definir o domínio do sistema com EDA exploratória e API FastAPI autenticada como base.

| Dados analisados | API verificada | Evidências |
|---|---|---|
| 3.000 mensagens<br>20 intenções | JWT funcional<br>26 testes aprovados | Notebook executado<br>DFD e análise CIA |

O projeto organiza a base de atendimento e estabelece autenticação desde o início. Predição, agente, identificação de fraude e autorização de benefícios ficam para etapas posteriores.

Repositório público:
github.com/lenagomesz/tourshield-api-pb-tp1

Este relatório acompanha o código, os dados e o notebook versionados. O dataset não contém fraude confirmada ou coordenadas GPS.

# 01 / Domínio e escolha do dataset

O TourShield atende solicitações de reservas, viagens, localização e recompensas. A intenção será futuramente usada para encaminhar o atendimento; autenticação não equivale a autorização de resgate ou comprovação de localização.

| Item | Escolha documentada |
|---|---|
| Nome e autoria | CLINC150 - recorte curado TourShield. Stefan Larson et al., Clinc, 2019. |
| Fonte | github.com/clinc/oos-eval; arquivo data/data_full.json |
| Licença | CC BY 3.0 Unported. Cópia em data/LICENSE-CLINC150.txt. Código do projeto sob MIT. |
| Origem e idioma | Enunciados de crowdsourcing em inglês, com intenção única; não são tickets reais de uma agência. |
| Recorte | 20 rótulos selecionados explicitamente; 150 mensagens por rótulo. IDs e split adicionados; sem tradução. |
| Justificativa | Texto e intenção disponíveis, mais de 500 exemplos e categorias úteis de turismo, reservas, localização e recompensas. |

## Intenções selecionadas

book_flight, book_hotel, cancel_reservation, confirm_reservation, car_rental, flight_status, lost_luggage, carry_on, travel_alert, travel_notification, travel_suggestion, international_visa, vaccines, plug_type, current_location, directions, distance, share_location, redeem_rewards, rewards_balance

## Rastreabilidade

Revisão fixada: 828f8093932c8fe6ca7936c3d2e52903b1c523de

SHA-256 do arquivo bruto:
36923c3705a59e08fe9c3883d8bc2dd966ef93e22cb78ac41171782a698d56e0

O manifesto data/provenance.json guarda URL exata, hash do CSV e transformações. O script prepare_data.py reutiliza a revisão fixada. Os CSVs presentes permitem executar a EDA sem rede.

Limitação temática: recompensas são genéricas. Não há evidência de que pertençam a programa turístico. Elas apoiam o desenho do atendimento, sem permitir avaliar abuso de benefícios.

# 02 / Qualidade e preparação dos dados

| Verificação com Pandas | Resultado |
|---|---|
| Shape original | (3.000, 4) |
| Dtypes | sample_id, message, intent, split: string |
| describe(include='all') | 3.000 IDs distintos; 3.000 textos distintos; 20 intenções; 3 splits |
| Ausentes por coluna | sample_id=0; message=0; intent=0; split=0 |
| Duplicatas | 0 integrais; 0 mensagem/intenção; 0 normalizadas |
| Conflitos e perdas | 0 conflitos de rótulo; 0 linhas removidas ou imputadas |
| Exportação limpa | (3.000, 6), incluindo n_chars e n_words |
| Splits preservados | Treino 2.000; validação 400; teste 600. Sobreposição textual normalizada entre splits: 0. |

## Decisões de limpeza

A rotina remove texto/intenção ausentes ou vazios, caso existam. Aplica strip ao texto e cria chave auxiliar casefold com espaços uniformizados para auditar duplicatas; não remove pontuação, entidades ou palavras.

Se ocorrer repetição da mesma chave e intenção, preserva primeiro teste, depois validação, depois treino, sem mover amostras. Conflitos de rótulo são exportados e excluídos para revisão. Nesta execução nenhuma dessas regras removeu linhas.

Mensagens longas são mantidas: 98 registros (3,27%) ultrapassam 18 palavras, limite Q3 + 1,5 IQR. O tamanho, sozinho, não justifica excluir um chamado.

Toda seleção, limpeza e estatística usa Pandas. Auditorias completas em reports/; códigos equivalentes em eda/eda.py e eda/eda.ipynb.

# 03 / Distribuições e estatísticas

| Medida | Caracteres | Palavras |
|---|---|---|
| n | 3.000 | 3.000 |
| Média / desvio padrão | 50,09 / 17,37 | 10,26 / 3,65 |
| Mínimo / máximo | 8 / 136 | 2 / 28 |
| Q1 / mediana / Q3 | 38 / 48 / 60 | 8 / 10 / 12 |

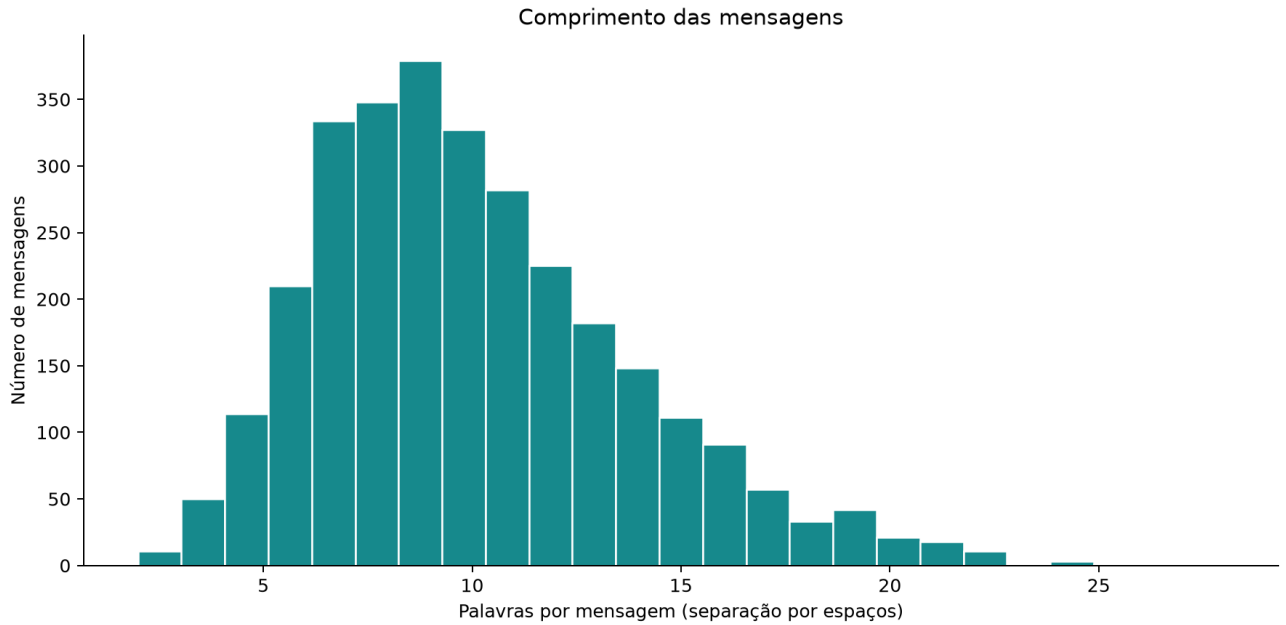



Figura 1. Comprimento em palavras; tokens definidos por espaços. Fonte: CLINC150, recorte e elaboração própria.

O centro está próximo de 10 palavras, com cauda à direita até 28. Os percentis e o desvio padrão descrevem dispersão; não foi assumida distribuição normal nem executado teste inferencial.

Os comprimentos são derivados dos textos. Não existem variáveis numéricas de GPS ou transações que possam sustentar análise de fraude ou deslocamento.

# 04 / Distribuição das intenções

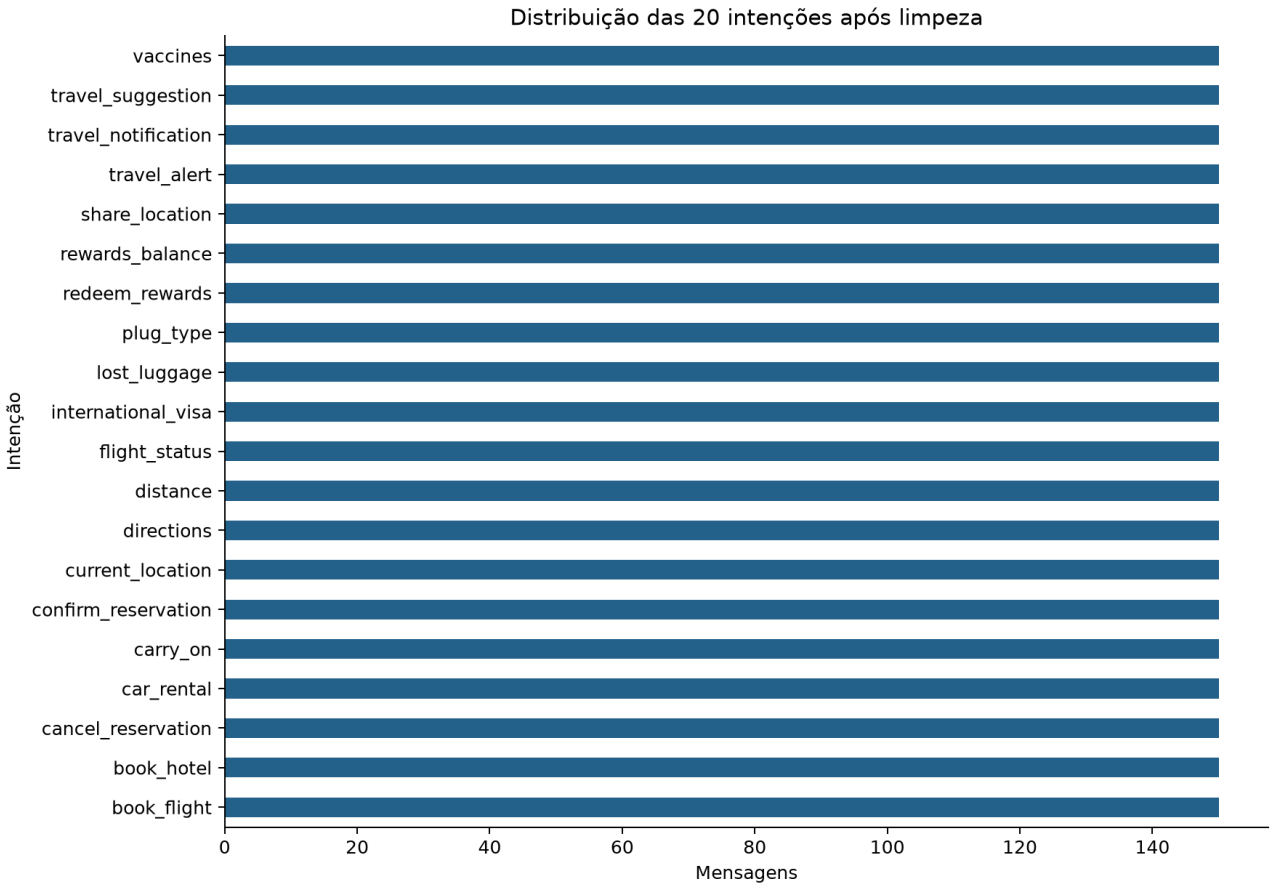



Figura 2. Contagens após a limpeza. Fonte: CLINC150, recorte e elaboração própria.

Todas as 20 classes possuem 150 mensagens, correspondentes a 5% do total. Por classe, foram preservados 100 exemplos de treino, 20 de validação e 30 de teste.

**Hipótese 1:** a demanda real por atendimento terá distribuição diferente da uniforme. O gráfico reflete a amostragem balanceada do benchmark, e não a popularidade de cada intenção entre turistas.

**Como validar:** coletar chamados reais autorizados, contar intenções por período e região e comparar as proporções, documentando o método de amostragem. Nesta base não se pode estimar prevalência operacional.

# 05 / Comprimento e hipóteses

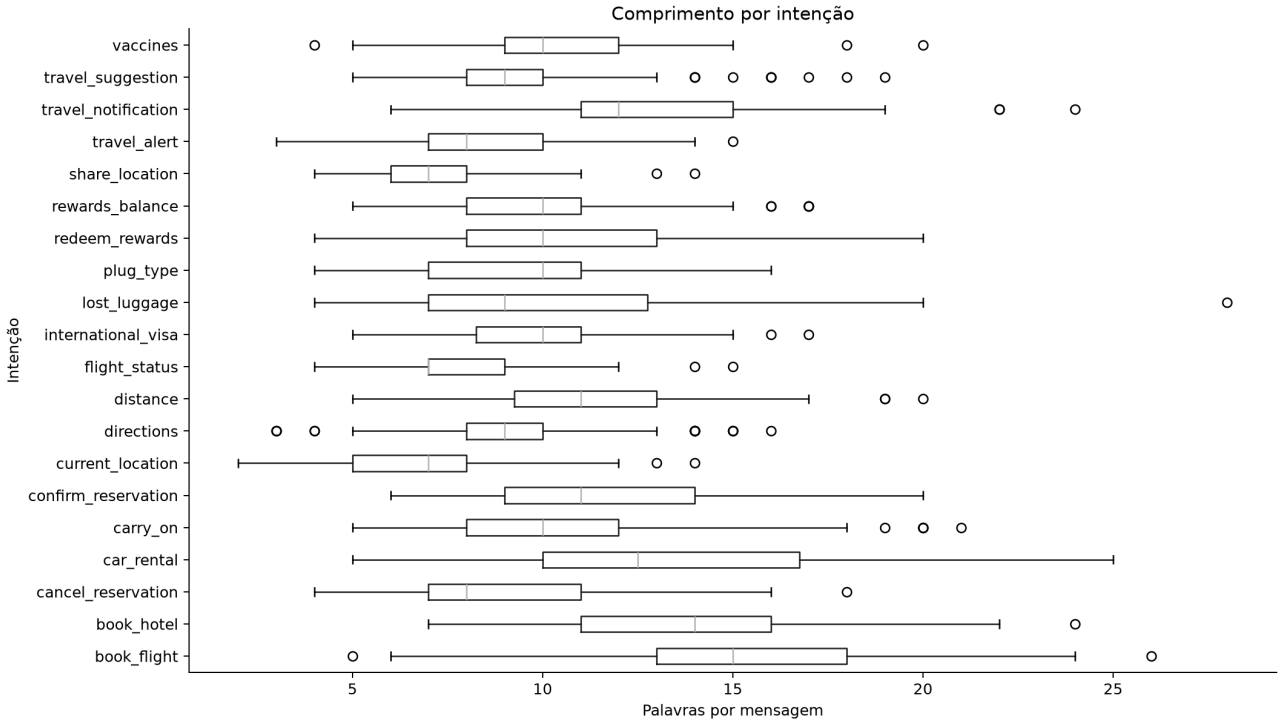



Figura 3. Medianas, intervalos interquartis e valores extremos por intenção. Fonte: elaboração própria sobre CLINC150.

**Hipótese 2:** pedidos de reserva exigem mais contexto textual que consultas de localização. Reservas: n=750, mediana 12 palavras; localização: n=600, mediana 8. book_flight tem mediana 15; book_hotel, 14; current_location e share_location, 7.

**Hipótese 3:** comprimento isolado pode não distinguir saldo e resgate de recompensas. rewards_balance e redeem_rewards têm mediana 10; médias 10,03 e 10,32, com sobreposição no boxplot.

H2: validar a diferença em amostra externa com bootstrap e teste não paramétrico predefinido. H3: comparar futuramente um baseline de comprimento com representação textual, usando macro-F1 e matriz de confusão. Não há modelo ou conclusão causal neste TP.

# 06 / API modular e autenticação

| Rota | Entrada / acesso | Saída |
|---|---|---|
| GET /health | Pública | 200: status="ok" |
| POST /auth/token | Form username/password | 200: JWT bearer; falha 401 |
| POST /predict | Bearer JWT e JSON message; GPS opcional em par | 200: placeholder; sem token 401; entrada inválida 422 |

## Arquitetura

main.py monta a aplicação; app/routes organiza endpoints; models.py define schemas Pydantic; database.py encapsula SQLite; security.py cuida de hashing e JWT; config.py carrega configuração. Cadastro de usuário ocorre por CLI local.

## Fluxo autenticado

OAuth2PasswordBearer obtém o Bearer token. O login verifica hash Argon2 e emite JWT HS256 de 15 minutos. A validação exige sub, iat, exp, iss e aud, aceita apenas HS256 e consulta se a conta permanece ativa. Sem segredo externo de pelo menos 32 bytes, o startup falha.

O JWT é assinado, não cifrado; não inclui senha, texto ou GPS. A resposta de token usa no-store. O banco armazena apenas usuário, hash e estado ativo, com SQL parametrizado e fechamento explícito das conexões.

## Contrato do placeholder

```
{"intent": null, "status": "placeholder",
 "detail": "Modelo não implementado; nenhum benefício
            ou reserva foi autorizado."}
```

Texto em branco é rejeitado; limite de 4.000 caracteres. Latitude [-90,90] e longitude [-180,180] devem ser informadas juntas. Campos extras e valores não finitos são rejeitados. Texto e localização não são persistidos nem retornados.

# 07 / DFD e fronteiras de confiança

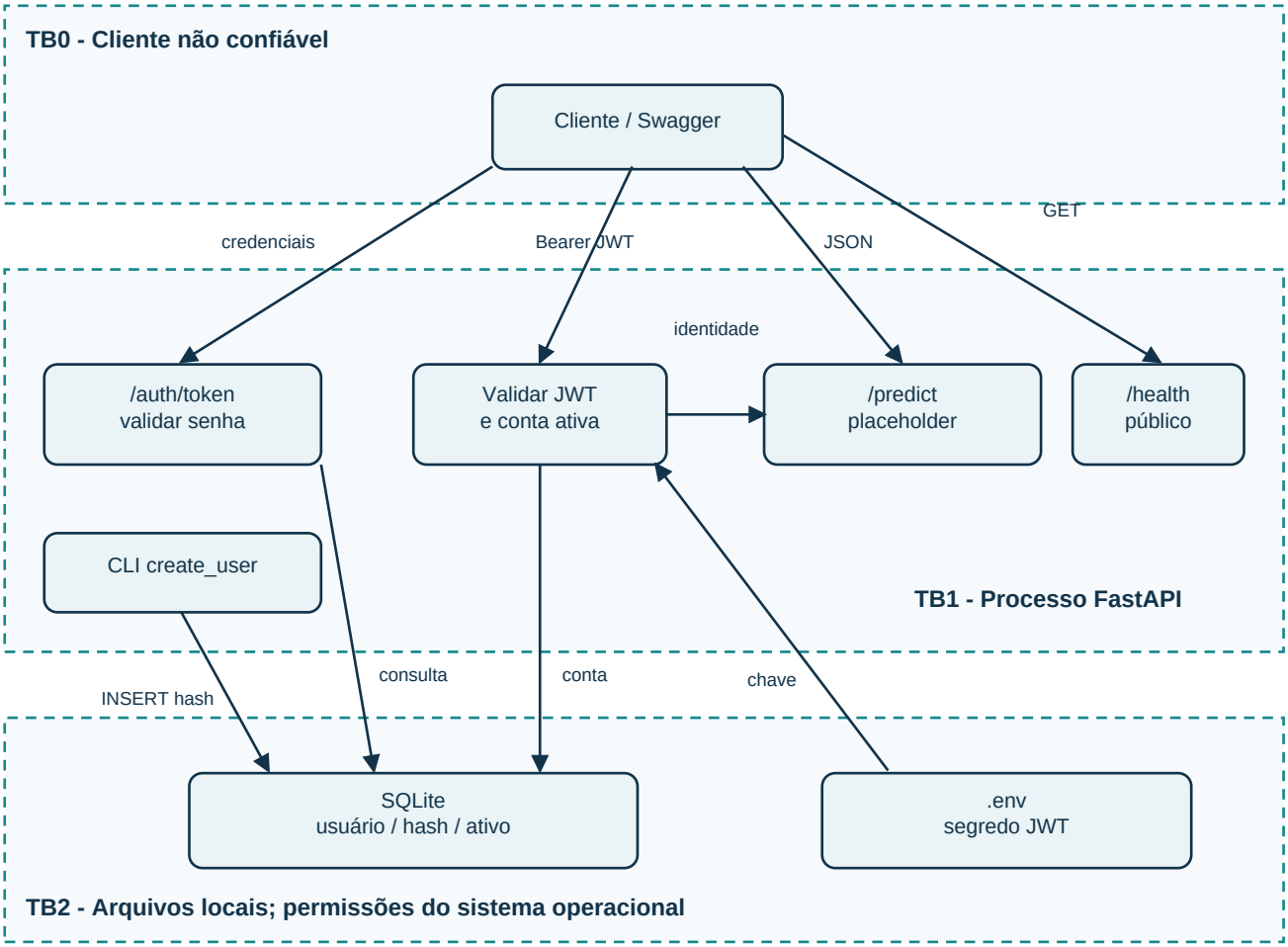



Figura 4. DFD básico da API. As áreas tracejadas marcam trust boundaries. A versão Mermaid completa está em docs/security.md.

**TB0/TB1:** senha, token, mensagem e coordenadas atravessam a fronteira entre cliente e servidor. Saídas: status público, JWT ou 401, e placeholder ou erro. No desenvolvimento o transporte usa HTTP em loopback; HTTPS é requisito antes de exposição externa.

**TB1/TB2:** SQLite fornece usuário, hash e flag ativo; .env fornece a chave para emissão e validação JWT. É fronteira lógica de permissões sobre arquivos na mesma máquina, sem isolamento físico. A CLI administrativa grava usuário e hash.

As saídas voltam ao cliente pelo mesmo canal HTTP. Não há acesso a motor de reservas, serviço de GPS, provedor de benefícios ou modelo. Dataset e notebook pertencem ao fluxo offline de análise.

Localização declarada pelo cliente é não confiável. Um token válido demonstra sessão, mas não comprova local físico, titularidade de uma reserva ou elegibilidade para benefício.

# 08 / CIA e riscos do domínio

| Componente | Confidencialidade | Integridade | Disponibilidade |
|---|---|---|---|
| Cliente / canal | Senha, JWT, texto e GPS; HTTPS externo pendente | Validar tudo recebido; GPS pode ser falso | Timeouts e limites no proxy pendentes |
| /health | Somente serviço e status | Sem entrada variável | Sonda pública de vida; não verifica banco |
| Login / JWT | Argon2; token sem PII adicional; no-store | Assinatura, algoritmo fixo, claims e conta ativa | Expiração 15 min; rate limiting pendente |
| /predict | Não armazena ou reflete texto/GPS | Schemas, faixas, campos extras rejeitados | Placeholder leve; limite pré-parsing pendente |
| SQLite / CLI | Hash, não senha; ACL do SO necessária | Parâmetros SQL, PK e transações | Timeout 5 s; backup a configurar |
| .env / chave | Fora do Git; proteger permissões | Segredo sem valor padrão | Rotação invalida todos os tokens |
| Dataset / EDA | Benchmark público; sem novos dados pessoais | Commit fixo, SHA-256 e bruto preservado | Dados presentes; execução offline |

## Fraude de benefícios

Nos próximos TPs, saldo e elegibilidade devem ficar no servidor. Vincular reserva ao usuário autenticado, autorizar por recurso, usar transações e idempotência e auditar resgates. JWT sozinho não impede acesso indevido por ID ou resgate duplicado.

## Geolocalização e limites atuais

Geofence isolada não comprova presença: GPS declarado pode ser falsificado. Dados independentes e consentidos serão necessários. Esta versão não tem TLS/proxy, MFA, rate limiting, revogação individual de JWT, backup automatizado ou monitoramento. Não está pronta para produção.

# 09 / Execução, evidências e referências

## Instalação e execução

```
python -m venv .venv
.\.venv\Scripts\Activate.ps1
python -m pip install -r requirements.txt
# Configure .env com JWT_SECRET aleatório (ver README).
python -m scripts.create_user helena
uvicorn main:app --reload
# Em outro terminal:
python eda/eda.py
python -m pytest -q
```

O README inclui geração segura do segredo, exemplos PowerShell para obter token e chamar a API, estrutura de pastas e alternativas à ativação do ambiente. O notebook também executa a partir da pasta eda/ com o dataset presente.

| Verificação executada | Evidência / resultado |
|---|---|
| Notebook | 9 células executadas, com tabelas e três imagens; sem erro |
| Testes automatizados | 26 aprovados; reports/tests.xml |
| HTTP real com Uvicorn | /health 200; /predict sem token 401; login 200; /predict autenticado 200 |
| Segurança testada | Credencial incorreta, JWT expirado/assinatura/claims/algoritmo inválidos, conta inativa e validação de entrada |

Um aviso de depreciação do TestClient/httpx permanece no ambiente verificado; não houve falha de teste. Relatórios estão em reports/ e o DFD em docs/security.md.

## Referências e entrega

Larson et al. (2019). *An Evaluation Dataset for Intent Classification and Out-of-Scope Prediction*. EMNLP-IJCNLP. aclanthology.org/D19-1131.
Dataset e licença: github.com/clinc/oos-eval; CC BY 3.0.
FastAPI: documentação oficial de OAuth2 e JWT.

Entrega: github.com/lenagomesz/tourshield-api-pb-tp1. Enviar o link e este PDF no campo da disciplina. O repositório contém os artefatos executáveis; o relatório não os substitui.